

Exploitation of SMB Null Session on Metasploitable using smbclient and enum4linux

Santi Lo Faro

Data: 21/05/2026

Introduzione

In questo laboratorio è stata analizzata una vulnerabilità SMB legata alle Null Session all'interno della macchina vulnerabile Metasploitable. L'obiettivo dell'attività era verificare la possibilità di accedere anonimamente alle condivisioni SMB del target utilizzando strumenti di enumerazione e accesso remoto come enum4linux e smbclient.

L'attività è stata svolta utilizzando Kali Linux come macchina attaccante e Metasploitable come sistema bersaglio all'interno di una rete locale controllata. Lo scopo del laboratorio era comprendere come configurazioni SMB non sicure possano permettere a un utente non autenticato di ottenere informazioni sensibili e accedere a risorse condivise senza credenziali valide.

Durante il test è stato inoltre dimostrato come sia possibile sfruttare alcune configurazioni errate delle share SMB per raggiungere directory sensibili del sistema Linux bersaglio, fino alla lettura del file /etc/passwd.

Enumerazione SMB con enum4linux

La prima fase del laboratorio è consistita nell'analisi del target tramite enum4linux, uno strumento molto utilizzato nel penetration testing per effettuare enumerazione SMB e NetBIOS su sistemi Linux e Windows.

Dopo aver identificato l'indirizzo IP della macchina Metasploitable, è stato eseguito il comando:

```
enum4linux 192.168.50.200
```

L'output ottenuto ha mostrato numerose informazioni relative al sistema bersaglio. Tra queste erano presenti:

- nome host
- workgroup
- servizi SMB disponibili
- informazioni NetBIOS
- versioni Samba
- condivisioni accessibili
- verifica delle sessioni anonime

Durante l'analisi è stato osservato che il server consentiva connessioni anonime senza autenticazione. Questo comportamento rappresenta una grave vulnerabilità di sicurezza perché permette a un attaccante di effettuare attività di enumerazione senza possedere credenziali valide.

L'output di enum4linux ha inoltre confermato la presenza del servizio Samba utilizzato da Metasploitable. Samba è una suite software che implementa il protocollo SMB/CIFS nei sistemi Linux e Unix, consentendo la condivisione di file e stampanti con sistemi Windows e altri host di rete.

Dal punto di vista offensivo, strumenti come enum4linux risultano estremamente utili nelle prime fasi di un penetration test poiché consentono di raccogliere informazioni dettagliate sull'infrastruttura bersaglio senza effettuare direttamente operazioni invasive.

Enumerazione delle share SMB con smbclient

Dopo la fase di enumerazione iniziale, è stato utilizzato smbclient per visualizzare le risorse condivise disponibili sul target.

Il comando eseguito è stato:

```
smbclient -L //192.168.50.200
```

Il parametro -L permette di ottenere la lista delle share SMB disponibili sul sistema remoto.

L'accesso anonimo è risultato immediatamente consentito e il server ha restituito diverse condivisioni, tra cui:

- print\$
- tmp
- opt
- IPC\$

La presenza della share tmp accessibile anonimamente rappresentava un elemento particolarmente interessante dal punto di vista del penetration testing, poiché directory temporanee configurate in modo errato possono essere sfruttate per ottenere accessi non autorizzati o manipolare file all'interno del sistema.

L'accesso anonimo alle share SMB costituisce una cattiva configurazione molto pericolosa perché espone direttamente porzioni del filesystem a utenti non autenticati.

Accesso alla share tmp

Successivamente è stato effettuato l'accesso diretto alla share tmp tramite il comando:

```
smbclient //192.168.50.200/tmp
```

Una volta stabilita la connessione, il terminale ha restituito una shell SMB interattiva identificata dal prompt:

```
smb: \>
```

All'interno della sessione SMB è stata attivata la modalità POSIX, necessaria per utilizzare alcune funzionalità avanzate del filesystem Linux remoto.

Durante l'analisi è stato osservato che il server supportava estensioni CIFS compatibili con operazioni POSIX, consentendo quindi la creazione di link simbolici.

Creazione del symlink verso la root del sistema

La parte più interessante del laboratorio è consistita nello sfruttamento della share tmp per creare un collegamento simbolico verso la root del filesystem della macchina Metasploitable.

È stato creato un symlink chiamato rootfs utilizzando una lunga sequenza di parent directory (../) per risalire progressivamente il filesystem fino alla directory root del sistema Linux bersaglio.

Questo comportamento è possibile a causa di una configurazione SMB non sicura che consente traversal del filesystem tramite link simbolici.

Dopo la creazione del symlink, utilizzando il comando ls, è stato possibile osservare il contenuto reale della root del sistema operativo remoto. Tra le directory visualizzate erano presenti:

- /bin
- /etc
- /usr
- /var
- /root
- /tmp

La possibilità di raggiungere direttamente la root del filesystem tramite una share SMB anonima rappresenta una vulnerabilità estremamente critica perché consente accesso a directory e file sensibili del sistema operativo.

Lettura del file /etc/passwd

Una volta ottenuto l'accesso alla root del filesystem remoto, è stata raggiunta la directory /etc, contenente numerosi file di configurazione Linux.

Tra questi è stato individuato il file /etc/passwd.

Il file è stato scaricato e visualizzato tramite il comando:

```
more passwd
```

Il contenuto del file mostrava l'elenco degli utenti presenti sul sistema, inclusi:

- utenti di sistema
- servizi
- account applicativi
- shell associate agli utenti

Nei sistemi Linux moderni il file /etc/passwd non contiene direttamente gli hash delle password, che vengono invece salvati nel file /etc/shadow. Tuttavia, il file passwd rimane comunque molto utile durante un'attività di penetration testing perché permette di ottenere:

- nomi utenti validi
- informazioni sui servizi attivi
- shell utilizzate
- struttura del sistema

Queste informazioni possono essere utilizzate nelle fasi successive di un attacco per effettuare:

- brute force
- password spraying
- privilege escalation
- enumerazione avanzata

Impatto della vulnerabilità

Il laboratorio ha evidenziato come una configurazione SMB errata possa esporre informazioni estremamente sensibili anche senza autenticazione.

L'accesso anonimo alle share SMB, combinato con la possibilità di creare symlink verso directory superiori del filesystem, può permettere a un attaccante di:

- leggere file sensibili
- effettuare enumerazione del sistema
- raccogliere utenti validi
- ottenere informazioni sul sistema operativo
- preparare attacchi successivi

In ambienti reali questo tipo di configurazione potrebbe portare a compromissioni molto gravi, soprattutto in infrastrutture legacy o sistemi non correttamente aggiornati.

Tecniche di mitigazione

Per mitigare questo tipo di vulnerabilità è fondamentale disabilitare l'accesso anonimo alle share SMB e limitare l'accesso esclusivamente agli utenti autenticati.

Le condivisioni dovrebbero inoltre essere configurate utilizzando permessi molto restrittivi, evitando l'esposizione di directory temporanee o percorsi sensibili.

È inoltre importante:

- aggiornare Samba alle versioni più recenti
- disabilitare configurazioni legacy SMB
- limitare il traversal del filesystem
- monitorare accessi SMB sospetti
- utilizzare firewall per limitare l'accesso alle porte SMB

In ambienti enterprise risulta fondamentale effettuare periodicamente attività di vulnerability assessment e penetration testing per individuare configurazioni insicure prima che possano essere sfruttate da un attaccante reale.

Conclusione

Il laboratorio ha permesso di comprendere concretamente i rischi associati alle Null Session SMB e alle configurazioni errate delle share Samba.

Attraverso strumenti come enum4linux e smbclient è stato possibile effettuare enumerazione anonima del sistema Metasploitable, identificare share accessibili senza autenticazione e sfruttare una configurazione insicura per raggiungere la root del filesystem remoto.

La lettura del file /etc/passwd ha dimostrato come vulnerabilità apparentemente semplici possano consentire la raccolta di informazioni estremamente utili durante un attacco informatico.